NIST CSF 2.0

Structure Overview

1. What is NIST CSF?

NIST CSF = **National Institute of Standards and Technology Cybersecurity Framework**.

- Developed by NIST, a U.S. federal agency, originally in response to a 2013 Executive Order aimed at improving critical infrastructure cybersecurity
- First released as **CSF 1.0** in 2014, updated to **1.1** in 2018, and majorly revised to **CSF 2.0** in February 2024
- It is **voluntary,** not a law, not a certification, not something you get "audited against" the way you do with ISO 27001
- Designed to be **flexible and sector-agnostic,** a hospital, a bank, a small startup, and a government agency can all use the same framework

2. Why NIST CSF Exists

Before CSF, organizations had no common vocabulary to talk about cybersecurity risk. NIST CSF gives:

- A common language for technical and non-technical stakeholders (a CEO and a security engineer can both understand "we're weak in Detect")
- A way to communicate risk posture to a board or to business partners

3. The Three Main Components of CSF

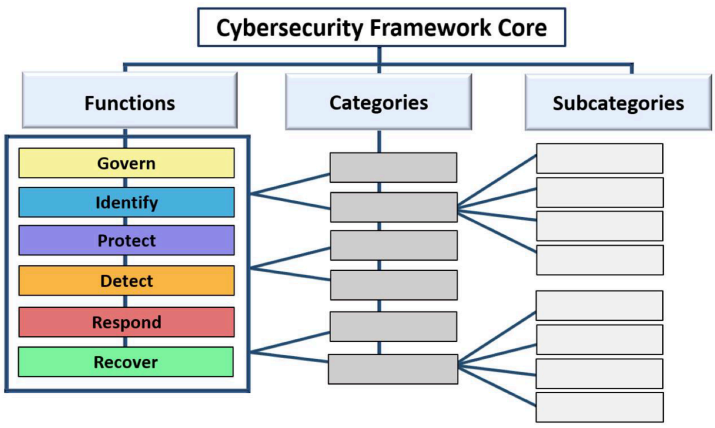


Fig. 1. CSF Core structure

The Core :

The CSF core includes functions, categories and subcategories that details each outcome. These outcomes can be understood by a broad audience, including executives, managers, and practitioners, regardless of their cybersecurity expertise.

Example: Function: Protect (PR) → Category: Data Security (PR.DS) → Subcategory: PR.DS-01 — Data-at-rest is protected

B. Organizational Profiles:

A snapshot of where an organization currently stands ("Current Profile") vs. where it wants to be ("Target Profile"). The gap between the two becomes the improvement roadmap.

C. Tiers :

Describe the *rigor and sophistication* of an organization's cybersecurity risk management practices — not a maturity score for each function, but an overall characterization. Four tiers:

Tier 1: Ad hoc
↓
Tier 2: Risk-informed
↓
Tier 3: Repeatable
↓
Tier 4: Adaptive

Tie	Name	What it means
1	Partial	Risk management is ad hoc, reactive, informal
2	Risk	Risk practices exist but aren't formalized org-wide
3	Repeatable	Formal policies exist and are consistently applied
4	Adaptive	Continuously improving, adapts based on lessons learned and changing

4. NIST's official CSF 2.0 Quick Start Guide Summary



Fig. 2. CSF Functions

There are 6 main functions namely GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER. It was designed to help all organization sectors like industry, academia, government and nonprofit to manage and reduce their cybersecurity risks. It describes desired outcomes and provides an extensive list of online resources and Quick Start Guides(QSGs). While retaining the previous versions, the 2.0 framework highlights the importance of governance and supply chains. It also provides Implementation Examples and Informative References.

1) **GOVERN (GV)** - The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored.

2) **IDENTIFY (ID) -** The organization's current cybersecurity risks are understood.

3) **PROTECT (PR) -** Safeguards to manage the organization's cybersecurity risks are used.

4) **DETECT (DE) -** Possible cybersecurity attacks and compromises are found and analyzed.

5) **RESPOND (RS) -** Actions regarding a detected cybersecurity incident are taken.

6) **RECOVER (RC) -** Assets and operations affected by a cybersecurity incident are restored

1) GOVERN (GV)

The organization’s cybersecurity risk management strategy, expectations, andpolicy are established, communicated, and monitored.
Govern is basically the rulebook and the org chart for cybersecurity — who decides what matters, who's accountable, and what the company's risk tolerance actually is.

Key Categories Within Govern:

- **Organizational Context (GV.OC):** understanding the organization's mission, stakeholders, and legal/regulatory requirements that shape cybersecurity priorities
- **Risk Management Strategy (GV.RM):** the organization's risk appetite and tolerance are established and communicated
- **Roles, Responsibilities & Authorities (GV.RR):** who is accountable for what, e.g., a defined CISO role, board-level reporting lines
- **Policy (GV.PO):** cybersecurity policy is established and communicated
- **Oversight (GV.OV):** results of risk management activities are used to inform and adjust strategy
- **Cybersecurity Supply Chain Risk Management (GV.SC):** third-party/vendor risk is factored into overall governance

Real-World Examples

1. A company's board formally approves a cybersecurity policy and assigns a CISO with defined authority (GV.RR, GV.PO)
2. A retail company identifies that PCI-DSS compliance is a legal requirement shaping its security priorities (GV.OC)
3. A company sets a formal risk appetite statement: "We will not accept risks that could cause more than 4 hours of downtime" (GV.RM)

2) IDENTIFY (ID)

Understanding the organization's assets, data, systems, and risk exposure, you can't protect what you don't know you have. Identify is the 'know your environment' function - inventory, risk assessment, understanding what you actually have to protect.

Key Categories

- **Asset Management (ID.AM):** inventories of hardware, software, data, and systems
- **Risk Assessment (ID.RA):** identifying and analyzing cybersecurity risk to the organization
- **Improvement (ID.IM):** lessons learned and gaps are identified to improve future risk management

Real-World Examples

1. An IT team maintains an inventory of every laptop, server, and SaaS application the company uses (ID.AM)
2. A company runs an annual risk assessment identifying that its customer database is its highest-value, highest-risk asset (ID.RA)
3. After a phishing incident, the security team documents what worked and what didn't, feeding it into next year's plan (ID.IM)

3) PROTECT (PR)

Implementing safeguards to prevent or limit the impact of potential cybersecurity events. Protect is the 'lock it down' function - access controls, training, encryption, patching. This is usually the largest, most resource-heavy function in practice

Key Categories

- **Identity Management, Authentication & Access Control (PR.AA):** least-privilege access, MFA
- **Awareness & Training (PR.AT):** employees trained on security practices
- **Data Security (PR.DS):** protecting data at rest and in transit
- **Platform Security (PR.PS):** hardening systems, patch management
- **Technology Infrastructure Resilience (PR.IR):** ensuring infrastructure can withstand disruption

Real-World Examples

1. A company enforces MFA for all employee logins (PR.AA)
2. All new employees complete mandatory phishing-awareness training (PR.AT)
3. Customer data is encrypted both at rest in the database and in transit over HTTPS (PR.DS)
4. Servers are patched on a defined monthly cycle (PR.PS)

4) DETECT (DE)

Finding and analyzing cybersecurity events as they happen. Detect is the 'watch for trouble' function - monitoring, alerting, and figuring out whether something flagged is actually a problem.

Key Categories

- **Continuous Monitoring (DE.CM):** systems and networks are monitored to find anomalies
- **Adverse Event Analysis (DE.AE):** detected events are analyzed to understand scope and impact

Real-World Examples

1. A SIEM tool flags unusual login activity from an unfamiliar country at 3 AM (DE.CM)
2. A security analyst investigates a flagged alert and determines it's a false positive vs. a real compromise (DE.AE)
3. Intrusion detection systems (IDS) monitor network traffic for known attack signatures

5) RESPOND (RS) & RECOVER (RC)

Taking action once a cybersecurity incident has been detected. Respond is 'deal with the fire' - contain it, understand it, tell the right people.

Key Categories:

- **Incident Management (RS.MA):** the incident response process itself is executed
- **Incident Analysis (RS.AN):** understanding what happened and its impact
- **Incident Response Reporting & Communication (RS.CO):** notifying stakeholders, regulators, or affected individuals as required
- **Incident Mitigation (RS.MI):** containing and eradicating the threat

Real-World Example: A company detects ransomware on a server. The incident response team isolates the affected machine (RS.MI), investigates the entry point (RS.AN), and notifies affected customers per legal breach-notification requirements (RS.CO).

RECOVER

Restoring capabilities and services that were impaired by a cybersecurity incident. Recover is 'put things back together' - restore systems, communicate that things are back to normal

Key Categories:

- **Incident Recovery Plan Execution (RC.RP):** restoring systems from backups, rebuilding compromised infrastructure
- **Incident Recovery Communication (RC.CO):** informing stakeholders about recovery progress

Real-World Example: After the ransomware incident above, the company restores affected systems from clean backups (RC.RP) and sends a follow-up update to customers once services are fully restored (RC.CO).

6) Tiers, Profiles & How CSF Is Used With Other Frameworks

1. Implementation Tiers — Deeper Look

Tiers apply *across the whole organization*, not per-function. A company might be:

- Tier 1 (Partial) in a startup with no formal security program
- Tier 3 (Repeatable) in a mid-size company with documented policies consistently followed
- Tier 4 (Adaptive) in a mature enterprise that adjusts its security posture based on threat intelligence in real time

Note**:** Tiers are NOT a maturity score from 1–4 per function (that's a common misunderstanding). They describe the organization's *overall* risk management sophistication.

2. Profiles — Deeper Look

- **Current Profile:** where the organization is today, based on actual practice

- **Target Profile:** where the organization wants to be, based on business needs and risk tolerance
- The **gap analysis** between Current and Target Profile becomes the actual roadmap/action plan

Example: A company's Current Profile shows weak Detect capabilities (no SIEM, no monitoring). Its Target Profile requires strong Detect (due to new compliance requirements). The gap = "implement a SIEM, hire a SOC analyst."

3. How NIST CSF Pairs With Other Frameworks

This is one of the most commonly tested interview concepts:

- **NIST CSF tells you WHAT to focus on** (risk priorities, functions)
- **ISO 27001 and SOC 2 tell you HOW to prove you're doing it** (specific controls, formal certification/attestation)
- Many organizations use NIST CSF internally for self-assessment and strategic planning, then pursue ISO 27001 certification or a SOC 2 report to demonstrate compliance externally to customers/regulators
- They are **complementary, not competing** — a company can be "NIST CSF-aligned" while also being ISO 27001 certified